

РАЗРАБОТКА АКТИВНОЙ СИСТЕМЫ-ЛОВУШКИ¹

Л.К. БАБЕНКО, Е.П. ТУМОЯН, К.В. ЦЫГАНOK

ФГАОУ ВПО «Южный федеральный университет» Технологический институт в г. Таганроге
347928, г. Таганрог, пер. Некрасовский, 44, ГСП-17А
E-mail: rector@tti.sfedu.ru

В работе предлагается программная система активного поиска и анализа вредоносного программного обеспечения (активная система-ловушка). Отличием от существующих систем являются разработанные алгоритмы релевантного поиска вредоносного программного обеспечения в Интернете. Предлагаемая система опирается на гипотезу о связности Web-страниц с близкой тематикой (в данном случае – вредоносных страниц) и возможности поиска множества таких страниц путем анализа связей в некотором небольшом их подмножестве. Кроме того, для повышения релевантности используется проверка страниц и скачиваемого программного обеспечения с использованием сторонних систем проверки. Разработанная система обеспечивает высокую релевантность поиска, в частности, в результате экспериментов около 80% образцов, полученных данной системой, были опознаны как вредоносные.

Ключевые слова: системы программной защиты, защита информации, анализ вредоносного программного обеспечения.

ВВЕДЕНИЕ

Как известно, исследования в области обнаружения вредоносного программного обеспечения ведутся уже многие годы. Типовым и наиболее распространенным методом обнаружения вирусов является сигнатурный метод – вычисление последовательности байтов, которая характерна для данного вируса и не характерна для других программ.

Существуют улучшения сигнатурных методов – такие как нечеткие и эвристические сигнатуры. В настоящее время в антивирусных продуктах активно используются “песочницы”, которые позволяют производить запуск ПО без угрозы для основной системы. Кроме того, современные антивирусные и защитные системы используют поведенческий анализ, который основан на регистрации событий, происходящих в ОС на момент наблюдения.

Однако все приведенные методы требуют исследования конкретных образцов вредоносного программного обеспечения. Получение значительного количества наиболее актуальных образцов вредоносного ПО является одной из задач как в академических исследованиях, так и при разработке новых сигнатур антивирусными компаниями. Сбор образцов вредоносного ПО осуществляется с использованием так называемых систем-ловушек.

1. СУЩЕСТВУЮЩИЕ ИССЛЕДОВАНИЯ

Одним из механизмов обнаружения и получения новых образцов вредоносного ПО и новых видов сетевых атак является honeypot (система-ловушка) [1]. Исследования в области создания и реализации различных систем-ловушек ведутся уже более 20 лет. Существуют активные, или клиентские (HoneyMonkey), и пассивные (Nepenthes, Honeyd) ловушки, каждая из которых имеет свою область применения.

¹ Работа выполнена при поддержке Российского фонда финансирования фундаментальных исследований, грант 11-07-92693-ИНД_а.

Активные системы-ловушки выполняют поиск и проверку программного кода и веб-страниц с целью определения их вредоносности [2]. Очевидным преимуществом активных систем-ловушек по сравнению с пассивными является более высокая скорость пополнения базы вредоносного программного обеспечения.

Один из самых известных активных honeypot – HoneyMonkey [3], разработанный фирмой Microsoft. HoneyMonkey – автоматизированная система, которая пытается “подражать” действиям пользователя, осуществляющего навигацию в сети Интернет. Для проверки ссылок используется сеть из компьютеров (агентов). При нахождении такой ссылки агент HoneyMonkey производит посещение потенциально опасной страницы, а также загружает и устанавливает потенциально вредоносное ПО. Перед посещением сайта создается снимок памяти исполняемых программ и реестра. После посещения происходит сравнение состояния памяти, исполняемых программ и реестра. С использованием данной информации происходит анализ установленного (запущенного) ПО. Очевидно, что процесс проверки ссылки является весьма ресурсоемким и занимает значительное время.

Таким образом, одной из основных задач при разработке систем-ловушек является повышение релевантности поиска вредоносных Web-страниц. Известно, что значительная часть ссылок, проверяемых клиентским ПО систем-ловушек (до 80%), не являются вредоносными.

Целью данной работы является разработка метода точного поиска вредоносных страниц, а также разработка системы-ловушки в соответствии с данным методом.

2. МЕТОД ПОИСКА ВРЕДНОСНЫХ СТРАНИЦ

Метод поиска вредоносных страниц предназначен для обнаружения Web-страниц, которые содержат ссылки на вредоносный код. В основе разрабатываемого метода лежит концепция кластеров интересов (cluster of interests), используемая для повышения релевантности результатов при поиске в Web [4, 5]. Концепция предполагает, что Web-страницы с близкой тематикой связаны между собой, возможно, непрямыми связями. При этом с учетом гипертекстовой природы Web одним из основных индикаторов связности являются гиперссылки. Таким образом, поиск необходимой страницы можно рассматривать как поиск связанных элементов в пространстве Web-страниц, каждая из которых представляется узлом.

С учетом приведенных факторов перейдем к формальной постановке задачи сбора вредоносного программного обеспечения.

Пусть имеется множество страниц $V = \{v_i\}$. Тогда множество страниц называются связными $S = \{s_j\}$, если выполняется

$$\exists i, j: L(v_i, s_j) = 1, \quad (1)$$

где L – функция связности:

$$L(v_i, s_j) = 1, \text{ если со страницы } v_i \text{ есть ссылка на страницу } s_j, \\ = 0 \text{ – в противном случае.}$$

Расширим понятие связности путем введения не прямой связности. Пусть имеется множество страниц $V = \{v_i\}$, содержащих вредоносное программное обеспечение. Тогда множество страниц $S = \{s_j\}$ находится с ним в отношении не прямой связности, если:

$$\exists i, j: \Lambda(v_i, s_j) > 0, \quad (2)$$

где Λ – функция не прямой связности:

$L(v_i, s_j) = N$, если существует конечное множество страниц $S' = \{s'_k\}, k = 1..N$, такое, что:

$$L(v_i, s'_1) = 1, L(s'_1, s'_2) = 1, \dots, L(s'_{N-1}, s'_N) = 1, L(s'_N, s_j) = 1.$$

Таким образом, предлагаемые нами функции связности соответствуют отношениям связности, принятым в теории графов, если рассматривать каждую страницу как узел графа, наличие гиперссылки – как наличие ребра между узлами.

Предлагаемая модель позволяет построить группы связанных страниц. Однако, как отмечено в [6], для кластеризации с целью получения релевантных результатов необходимо наличие меры близости (или меры расстояния) между страницами.

При этом мы не можем рассматривать мощность множества S как меру расстояния, поскольку удаленные (в смысле количества переходов) страницы могут иметь близкую тематику.

В данной работе предлагается рассматривать в качестве меры близости страниц результаты их проверки сторонними системами классификации вредоносных страниц. В работе используются следующие системы проверки ссылок: Google Safebrowsing API, Anubis, Virus Total, Wepawet.

Необходимо учесть, что наличие положительного или отрицательного ответа от одной из систем проверки фактически не говорит о вредоносности страницы. Для получения более стабильной оценки была предложена следующая формула:

$$p = (VT(s_j) * 3 - Ggl(s_j) * 2 + Anubis(s_j) * 2 + Wep(s_j) * 1) / 6, \quad (3)$$

где функции VT, Ggl, Anubis, Wep принимают значения {0,2} и представляют собой результаты проверки ссылки соответствующей системой проверки.

Таким образом, метод поиска вредоносных страниц можно описать следующим образом:

1. Поиск начинается с некоторого стартового множества страниц V . Мощность данного множества не имеет принципиального значения. Однако, чем больше данное множество, тем более релевантными будут результаты сбора.

2. Выделяется множество ссылок S такое, что $L(v_i, s_j) = 1, \exists i, j$

3. Исполняемые файлы, а также файлы JavaScript, ссылки на которые имеются в данном множестве страниц, скачиваются. Обработанные страницы удаляются из множества V .

4. Каждая ссылка из множества S проверяется системами Google Safebrowsing API, Virus Total, Wepawet.

В соответствии с формулой (3) вычисляется интегральная оценка “вредоносности страницы” P .

5. $V = V \cup S$.

6. Страницы множества V ранжируются по значению P . Страницы с большим P проверяются первыми, страницы с минимальной вредоносностью проверяются последними.

7. Если множество V – не пустое, перейти к п. 2.

Легко показать, что множество страниц, полученное данным методом, будет находиться в отношении прямой (1) или не прямой (2) связности со страницами исходного множества V . При этом приоритет обработки страниц будет зависеть от показателя вредоносности страницы P .

3. РАЗРАБАТЫВАЕМАЯ СИСТЕМА

Разрабатываемая активная система-ловушка предназначена для сбора и последующей классификации вредоносного кода. Вследствие того, что honeypot является активным, он осуществляет поиск и загрузку образцов вредоносного ПО из сети Internet. На данный момент honeypot выполняет поиск исполняемых файлов формата PE, а также скриптов JavaScript.

Архитектура системы-ловушки представлена на рис. 1. Реализация включает программы на языке Python и базу данных SQL.

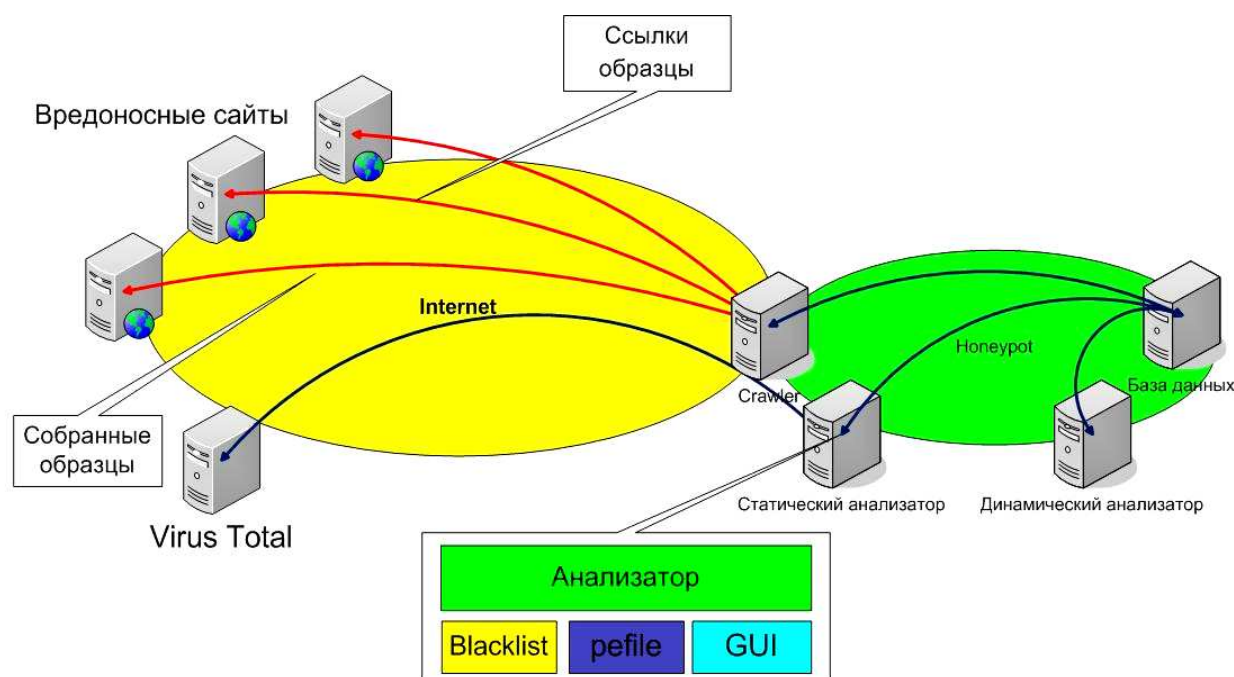


Рис. 1. Разрабатываемая система

Компонент Crawler осуществляет поиск исполняемых файлов по потенциально опасным ссылкам, имитируя поведение пользователя в сети. При поиске осуществляется проверка ссылок на наличие вредоносного программного обеспечения с использованием Black-листов Google Safebrowsing API, Virus Total, Wepawet и Anubis. Каждому потенциально опасному URL, где были найдены исполняемые файлы, на основе анализа полученных данных от вышеупомянутых средств ставится в соответствие рейтинг, позволяющий повысить релевантность поиска. Все ссылки, удовлетворяющие параметрам поиска, добавляются в имеющуюся базу данных. Начальные списки опасных ссылок включают гарантированно вредоносные ссылки (для ускорения поиска) и составляются по материалам специальных форумов.

Компонент Downloader загружает в локальную файловую систему файлы по ссылкам, находящимся в базе данных согласно рейтингу.

Статический анализатор производит анализ исполняемых файлов несколькими способами. Собранные данные обрабатываются статистическими методами и отображаются в виде графиков.

Динамический анализатор производит классификацию образцов вредоносного кода, даже если они не находятся в базе антивирусов VirusTotal, что характерно для нового или модифицированного вредоносного программного обеспечения. Разработка методов клас-

сификации вредоносного программного обеспечения является отдельной научной задачей и более подробно описана в работе [7].

Более подробно алгоритм работы системы-ловушки можно представить следующим образом:

1. Crawler обрабатывает ссылки на страницы с потенциально опасным ПО. Из каждой страницы извлекается дополнительный набор ссылок, которые добавляются в список анализируемых страниц.

2. Выполняется оценка рейтинга найденных ссылок путем проверки наличия элементов URL в Black-листах Google, Wepawet и VirusTotal. Рейтинг определяет приоритет обработки ссылки – скачивания и анализа, указанного в ссылке файла.

3. Выполняется статический анализ собранных образцов – определяется тип упаковщика, обнаружение антивирусами VirusTotal, а также геолокация источника вируса. Полученные данные анализируются и отображаются в виде графиков и диаграмм.

4. Выполняются динамический анализ образцов и классификация найденного образца на основе собранных ранее данных.

3. ПРОВЕДЕННЫЕ ЭКСПЕРИМЕНТЫ

В ходе экспериментов было собрано и проанализировано 3800 потенциально опасных ссылок, загружено 3003 файла, из которых 2698 были опознаны как вирусы:

- Антивирусом Касперского – 309;
- NOD32 – 387;
- Symantec – 512;
- McAfee – 732;
- Norman – 758.

Собранные статистическим анализатором данные отображены на рис. 2 – 5.

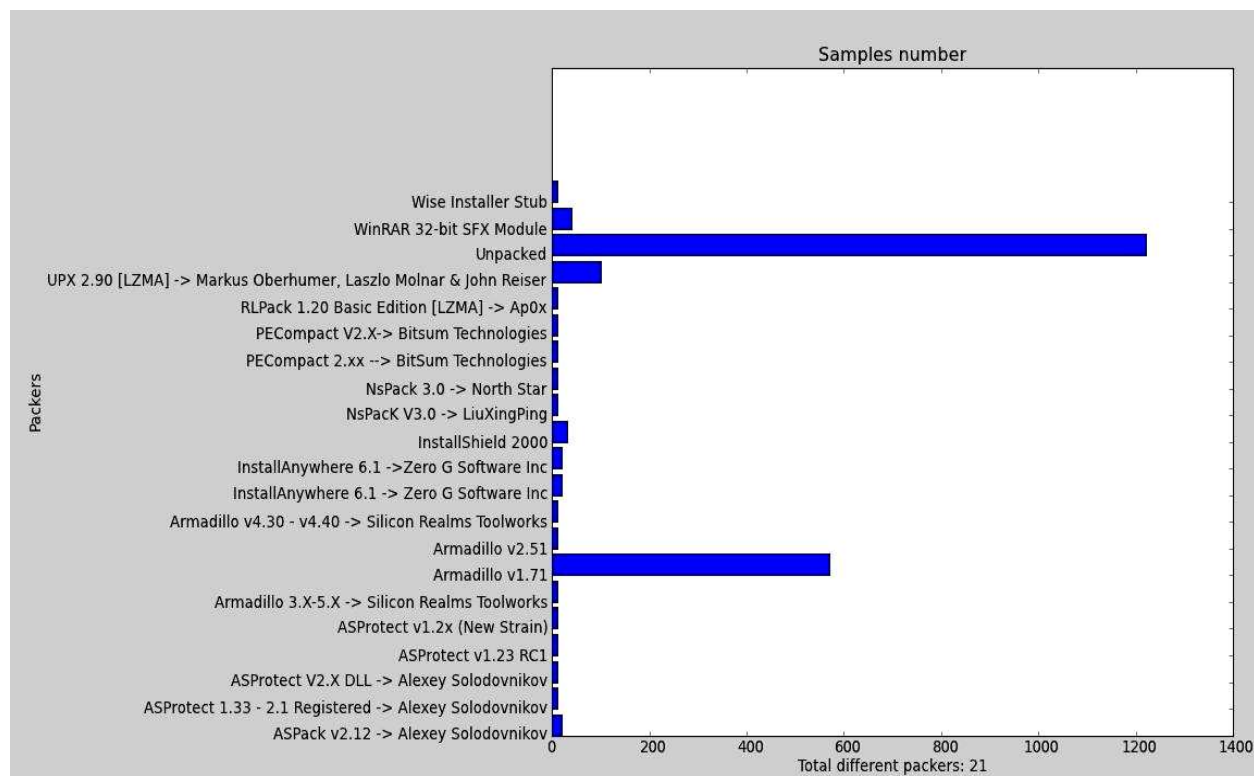


Рис. 2. Упаковщики, используемые в образцах

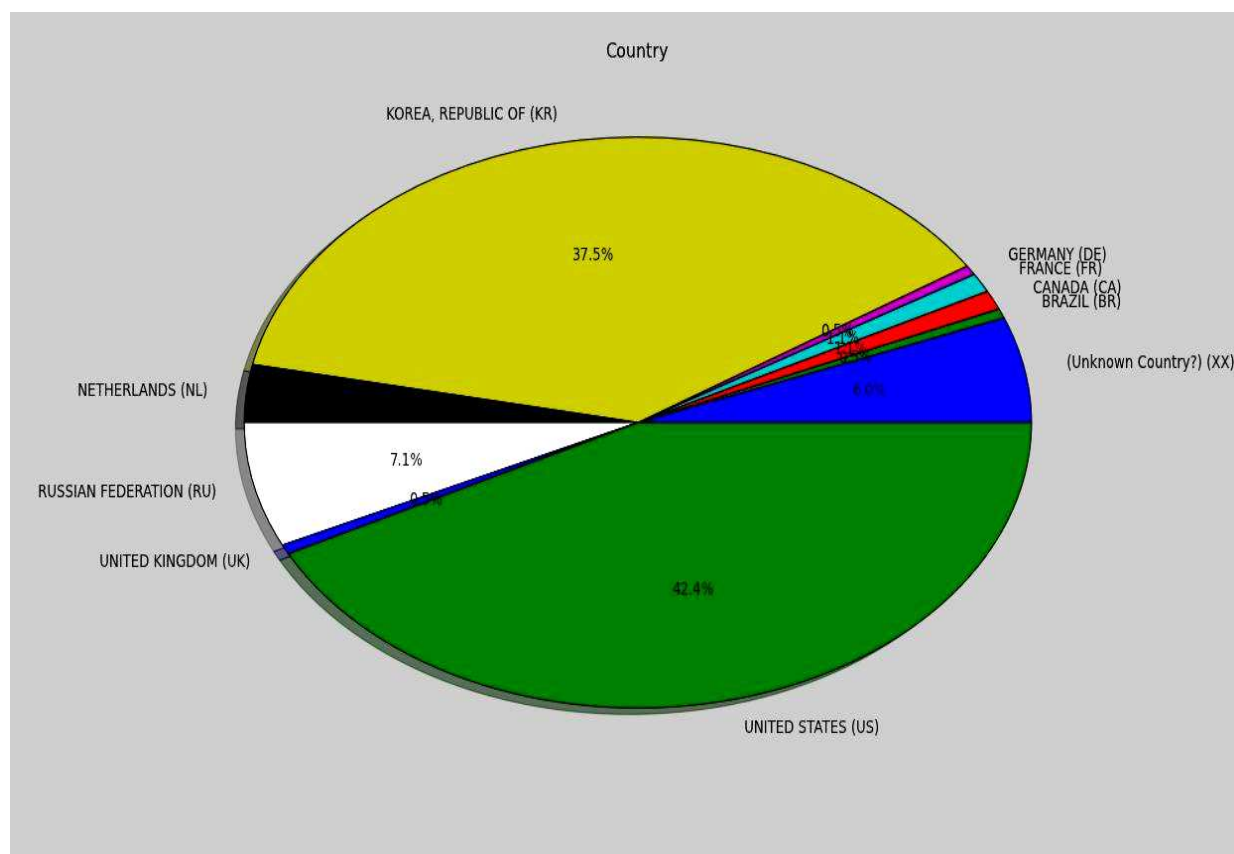


Рис. 3. Распределение ссылок с вредоносными файлами по странам в процентном соотношении

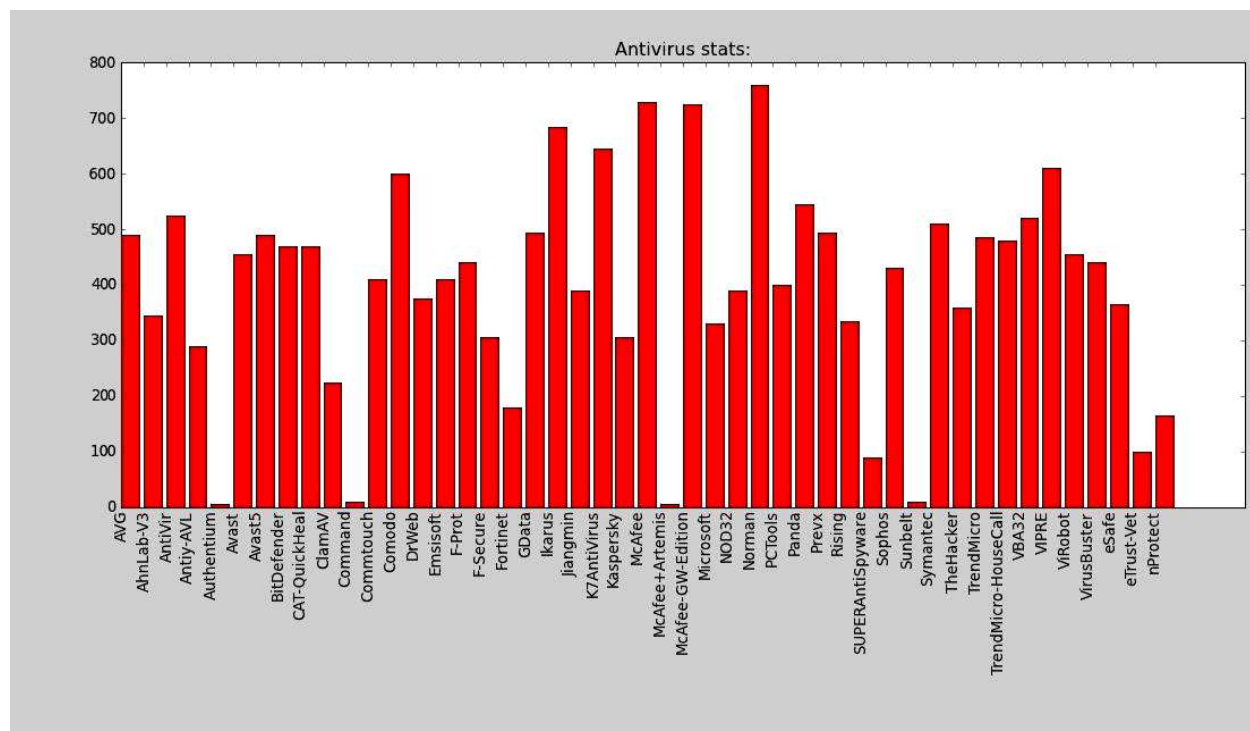


Рис. 4. Статистика обнаружения различными антивирусами VirusTotal

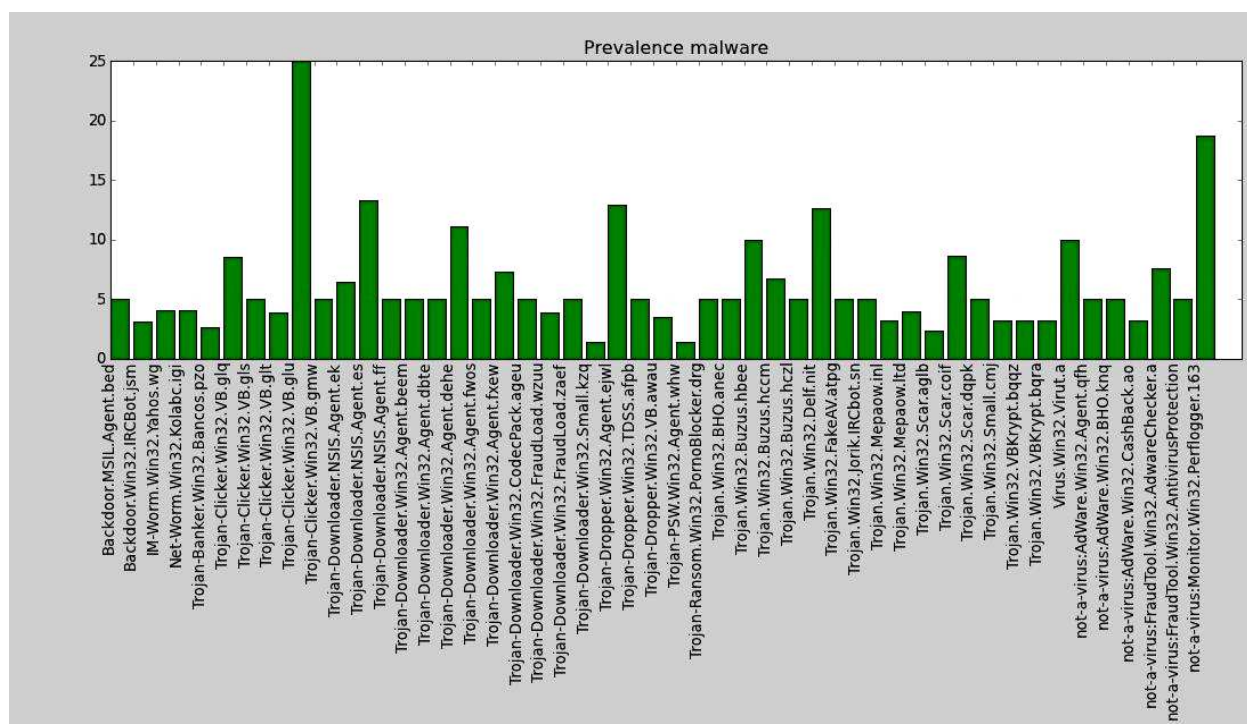


Рис. 5. Анализ типов вирусов, обнаруженных Антивирусом Касперского

Данные результаты представляют основу для ряда выводов в отношении текущего развития вредоносного программного обеспечения.

Значительная часть вредоносных ПО в настоящее время представляет собой упакованные или зашифрованные образцы. Это отражение общей тенденции к защите вирусов путем их упаковки. Часть антивирусных продуктов воспринимает упакованные файлы как вирусы а priori, что фактически может быть неверно.

Таким образом, актуальной задачей является разработка алгоритмов классификации полиморфного (упакованного или зашифрованного) и метаморфного программного обеспечения.

4. ВЫВОДЫ

Разработанный метод обеспечивает поиск вредоносных страниц с точностью около 71% (оценка получена как отношение количества скачанного вредоносного ПО к количеству обработанных ссылок). Дополнительным средством проверки вредоносности страниц является подключение сторонних систем оценки. В ходе проведения экспериментов было получено около 3000 образцов программного обеспечения, более 80% из которых – вредоносное ПО.

Одно из важнейших направлений дальнейших исследований – повышение точности отбора ссылок, поскольку снижение количества нерелевантных ссылок увеличит общую производительность системы-ловушки. Планируется использовать синтаксический разбор страниц и классификацию наборов синтаксических единиц с использованием статистических методов (искусственных нейронных сетей, Support Vector Machines, скрытых марковских моделей).

Вторым направлением развития предлагаемой системы является разработка и реализация алгоритмов анализа других типов файлов (pdf, wmf, jpg и т.д.) с целью обнаружения эксплойтов, внедряемых в файлы данных типов.

ЛИТЕРАТУРА

1. Spitzner L. Honeypots: Tracking Hackers. New-York, Addison-Wesley. 2002. 429 p.
2. Provos N., Holz T. Virtual Honeypots: From Botnet Tracking to Intrusion Detection. New-York, Addison-Wesley. 2007. 440 p.
3. Yi-Min Wang, Beck D., Xuxian Jiang, Roussev R., Verbowski C., Shuo Chen, King S. Automated Web Patrol with Strider HoneyMonkeys // Proceedings of the 2006 Network and Distributed System Security Symposium, 2006. P. 35–49.
4. Jiyang Chen, Zaiane O.R. An Unsupervised Approach to Cluster Web Search Results based on Word Sense Communities [Электронный ресурс]. Режим доступа: <http://webdocs.cs.ualberta.ca/~zaiane/postscript/WI08.pdf>, свободный.
5. Carpineto C., Osin'ski S., Romano G., Weiss D. A Survey of Web Clustering Engines [Электронный ресурс]. Режим доступа: <http://search.fub.it/claudio/pdf/CSUR09.pdf>, свободный.
6. Shelke R.S., Thakore D.S. Cluster Based Web Search Using Support Vector Machine [Электронный ресурс]. Режим доступа: <http://www.cscjournals.org/csc/manuscript/Journals/IJE/volume5/Issue1/IJE-242.pdf>, свободный.
7. Тумоян Е.П., Речков А.Л. Методы анализа вредоносного программного обеспечения // Актуальные аспекты защиты информации в Южном федеральном университете / Под ред. О.Б. Макаревича: Монография. Таганрог: Изд-во ТТИ ЮФУ, 2011. С. 94-101.

WORKING OUT AN ACTIVE SYSTEM-TRAP

L.K. BABENKO, E.P. TUMOYAN, K.V. TSYGANOK

Southern Federal University, the Institute of Technology in Taganrog
347928, Taganrog, 44, Nekrasovsky, lane 44, GSP-17A
E-mail: rector@tti.sfedu.ru

In this work the program system of active search and the analysis of the harmful software (active system-trap) is offered. It differs from existing systems by the developed algorithms of relevant search of the harmful software in the Internet. The offered system bases on a hypothesis about connectivity of Web-pages with close subjects (in this case - harmful pages) and possibilities of search of set of such pages by the analysis of communications in some their small subset. Besides, for relevance increase check of pages and the downloaded software with use of foreign systems of check is used. The developed system provides high relevance of search. In particular, as a result of experiments about 80 % of the samples received by given system, have been identified as harmful.

Key words: systems of program protection, information protection, analysis of the harmful software.

Работа поступила 01. 02. 2012 г.